Pivoting from a suspicious VPN login to a wider malware campaign

ANALYST	ROLE	ENVIRONMENT	HANDLING
Adi Prasetyo	SOC Analyst · Threat Intel	Training lab	Sanitised, no flags

SUMMARY

A VPN login was flagged as suspicious and tied to an unknown binary. I enriched the source and the file with open threat intel, then pivoted through shared infrastructure to find out whether this was a one-off or part of something bigger.

SCOPE

One VPN login event, its source IP and one SHA-256 file hash. Tools: the lab's threat intel platform, a public YARA repository and a vendor threat report.

METHOD

1. Looked up the ASN and hosting details of the source IP.
2. Checked which services were exposed on that IP.
3. Ran a reputation lookup on the file hash and recovered the original filename and detections.
4. Pivoted on the certificate's Subject Alternative Name (SAN) fields to list domains sharing the same certificate.
5. Found and read the public YARA rule that matches the sample.
6. Read the vendor report on the malware's affiliate model and mapped the behaviour to MITRE ATT&CK.

FINDINGS

- The hash already had community detections, so this was a known malicious sample, not a false positive.
- The certificate was shared across a large cluster of domains, which points to a coordinated campaign rather than an isolated host.
- A public YARA rule matched the sample to a known commodity infostealer family.
- The report describes affiliates routing access through proxy chains, which maps to ATT&CK T1090 (Proxy).

RECOMMENDATIONS

- Treat the account as compromised: disable it, reset the password, re-enrol MFA and revoke active VPN sessions.
- Block the hash, the IP and the linked domain cluster on EDR, proxy and firewall.
- Hunt for other logins from the same infrastructure and for the hash on other endpoints.
- Add a detection for VPN logins that originate from hosting provider ASNs.

WHAT THIS MEANS FOR THE ROLE

One IOC is only a starting point. Pivoting on shared infrastructure turned a single alert into a campaign-level picture, and that changes the response from resetting one password to blocking a whole cluster.